**THUYẾT MINH ĐỀ TÀI – NT539.R11**

AI ỨNG DỤNG TRONG MẠNG VÀ TRUYỀN THÔNG

# RAG tra cứu lỗ hổng cho thiết bị mạng có trích dẫn

GVHD: PGS.TS. Lê Kim Hùng

SVTH: Phan Mạnh Tân (23521404), Lê Xuân Hoàng (23520524)

## 1. Giới thiệu bài toán

**Bài toán:** Trả lời câu hỏi về các lỗ hổng đã công bố của phần mềm đang cài trên thiết bị trong mạng của người dùng, kèm trích dẫn nguồn. Hệ thống tự lấy tên phần mềm và phiên bản từ các máy đã đăng ký để tra cứu.

**Ví dụ câu hỏi:** *"Trong mạng của tôi, thiết bị nào đang chạy phần mềm có lỗ hổng bảo mật đã công bố?"*

**Kết quả:** Liệt kê thiết bị, phần mềm - phiên bản, CVE liên quan và nguồn trích dẫn. Thiết bị nào thiếu thông tin hoặc chưa có đủ tài liệu thì được ghi rõ là chưa đủ bằng chứng.

## 2. Dữ liệu

**Data collection:** Thu thập CVE/advisory từ NVD và nhà phát triển cho 8 phần mềm phổ biến, dễ cài trên Linux/VM. Mỗi phần mềm lấy 5 stable releases mới nhất; lưu version, affected range và source URL để xây knowledge base.

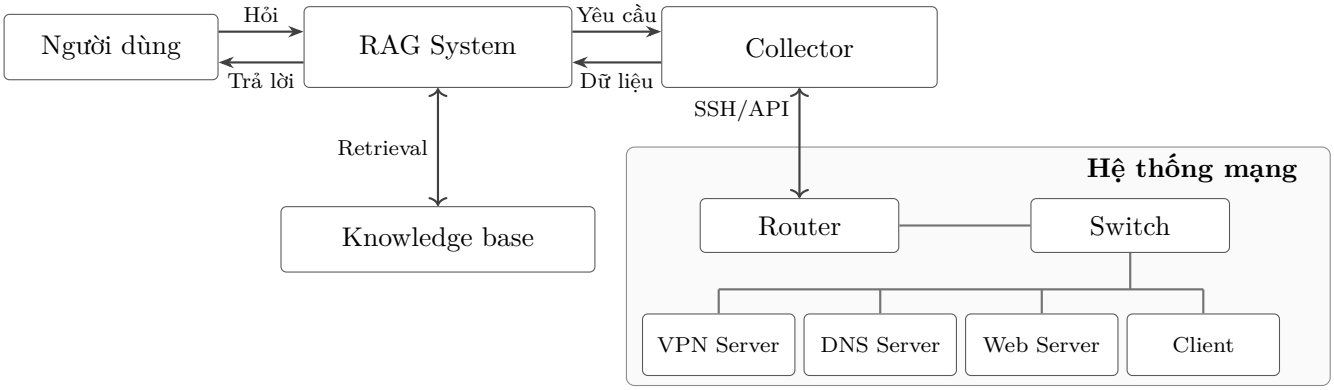
**Test setup:** Mỗi phần mềm dùng 2 test versions cố định (16 tổ hợp). Bổ sung advisory của test version nếu nằm ngoài 5 releases đã crawl.

| Software | Thành phần triển khai | Test versions |
|---|---|---|
| FRRouting | Router (Linux VM) | 8.5.2; 9.0.1 |
| Nginx | Web Server / Reverse Proxy | 1.24.0; 1.26.2 |
| Apache HTTP Server | Web Server | 2.4.49; 2.4.50 |
| BIND 9 | DNS Server | 9.18.19; 9.18.24 |
| OpenVPN | VPN Server / Client | 2.6.8; 2.6.10 |
| OpenSSH Portable | Router, Server và Client (SSH) | 9.6p1; 9.7p1 |
| HAProxy | Load Balancer / Reverse Proxy | 2.8.0; 2.8.9 |
| dnsmasq | DNS Server hoặc Router Linux | 2.86; 2.90 |

Collector cung cấp device, software và version; chỉ lấy thêm configuration khi advisory cần để xác định CVE. Các test instances được giữ cố định trong suốt đánh giá.

## 3. Phương pháp và kiến trúc hệ thống

**Mô hình tổng quát:** Người dùng hỏi RAG; RAG lấy dữ liệu các thành phần trong mô hình mạng từ collector, kết hợp kho CVE/advisory để xử lý và trả lời. Collector thu thập thông tin phần mềm từ hệ thống mạng.




*Hình 1. Luồng hỏi đáp và thu thập thông tin từ hệ thống mạng.*

**Test environment:** VM/container trên AWS cùng VPC, dựng bằng template/user-data. MGMT chạy RAG/collector; software đặt theo network role trong bảng. Switch minh họa kết nối mạng.

### 3.1. Indexing - Xây dựng cơ sở tri thức

Crawl → Processing → Chunking → Embedding → Vector Database

**Xây knowledge base trước khi sử dụng:** Thu thập CVE/advisory, chuẩn hóa, chia đoạn và lập chỉ mục Qdrant; giữ phiên bản và URL nguồn. Cập nhật theo đợt, không chờ câu hỏi mới thu thập tài liệu.

### 3.2. Retrieval - Truy xuất tài liệu

Câu hỏi → Thu thập phần mềm/phiên bản → Truy xuất CVE/advisory

Collector cung cấp hiện trạng máy; RAG chỉ truy xuất knowledge base đã xây, không lấy thêm tài liệu bên ngoài khi trả lời. Lọc phần mềm/phiên bản, đối chiếu cấu hình; thiếu bằng chứng thì báo rõ.

### 3.3. Generation - Sinh câu trả lời

Câu hỏi + Thông tin máy + Tài liệu → LLM → Câu trả lời + Trích dẫn

LLM trả lời theo bằng chứng đã truy xuất, kèm trích dẫn. Kiểm tra mã CVE và nguồn hỗ trợ; từ chối kết luận khi chưa đủ bằng chứng.

## 4. Baseline và thiết kế thực nghiệm

**Test set:** 100 câu nhóm tự viết từ 16 test instances và CVE/advisory, bao phủ device, software/version, CVE cụ thể, đối chiếu nhiều thiết bị và source evidence. Mỗi câu có expected CVEs/kết luận và source URL.

**Ba phương án so sánh:**

| System | Input / Processing |
|---|---|
| LLM | Câu hỏi người dùng + thông tin mạng từ collector. |
| RAG | Cùng câu hỏi + thông tin mạng; chỉ dùng thêm knowledge base đã xây. |
| Greenbone/OpenVAS | Nhận tập thiết bị/IP và quyền truy cập; quét và trả CVE theo thiết bị. |

Cả ba phương án được đánh giá trên cùng một hệ thống mạng tại cùng thời điểm. LLM/RAG dùng cùng model, tham số và yêu cầu trích dẫn; đối chiếu kết quả theo thiết bị, phần mềm/phiên bản và CVE với đáp án chuẩn.

## 5. Chỉ số đánh giá

| Metric | Evaluation | Systems |
|---|---|---|
| Accuracy | Độ đúng toàn câu sau khi đối chiếu từng thiết bị/phần mềm với đáp án. | LLM, RAG |
| Citation correctness | Source hỗ trợ đúng kết luận; kèm citation coverage. | LLM, RAG |
| CVE hallucination rate | Tỷ lệ CVE ID không tồn tại, xác minh bằng nguồn chính thức. | LLM, RAG |
| Precision / Recall | Tính theo từng thiết bị/phần mềm và CVE; báo TP, FP, FN. | Cả ba phương án |
| Latency | Báo riêng collector, mỗi câu LLM/RAG và lượt quét Greenbone. | Theo từng tác vụ |

Chấm theo đáp án đã duyệt; ghi riêng ca chưa hỗ trợ/lỗi ánh xạ. CVE vắng trong knowledge base chưa đủ để coi là mã bịa.